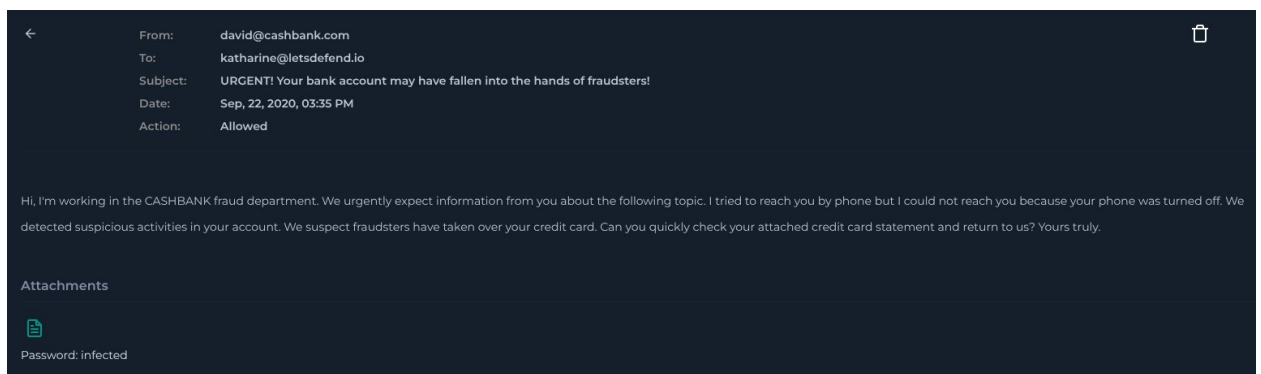


Event Information:

EventID :
19
Event Time :
Sep, 22, 2020, 03:40 PM
Rule :
SOC107 - Privilege Escalation Detected
Level :
Security Analyst
Source Address :
172.16.15.78
Source Hostname :
KatharinePRD
File Name :
creditcard
File Hash :
7299c49dd85069e47d6514ab5e10c264
File Size :
17K
Device Action :
Allowed

Analysis Steps:

It appears the delivery mechanism associated with this alert was a phishing email sent to 172[.]16.15.78 (KatharinePRD) from the external email david[@]cashbank[.]com.



In network logs we can see potential C2 activity stemming from this malicious file with an IP of 23[.]227.38.71 resolving to the domain hxxps://amesiana[.]com/.

Source Address contains "172.16.15.78"

All Time

1 events (before Feb. 28, 2021, 07:57 PM UTC)

< 1 >

< Hide Fields

INTERESTING FIELDS

type

source_address

source_port

destination_address

destination_port

raw_log

Field	Value
type	Firewall
source_address	172.16.15.78
source_port	12332
destination_address	23.227.38.71
destination_port	443
time	Feb, 28, 2021, 07:57 PM
Raw Log	
Request URL	https://amesiana.com/
Request Method	GET

1 row selected

On VirusTotal the file is listed as malicious by 41/62 Vendors. Based on the information provided the file seems to target Linux and may attempt privilege escalation.

41/62 security vendors flagged this file as malicious

27e5f0f4bb33a9f25e0e0c2a4aae57bdc3623e6cd664834e4ce60c9d

credilcard

Size: 17.46 KB

Last Analysis Date: 11 days ago

ef shared-lib checks-cpu-name detect-debug-environment cve-2017-16995 sets-process-name exploit 64bits

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 18

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Code insights

This sample is a Linux kernel privilege escalation exploit targeting eBPF (Extended Berkeley Packet Filter). It uses the bpf syscall (LINUX_MIB_BPF_0x141) to load a malicious BPF program and create maps via 'bpf' and 'bpf_prog_load'. The 'pwn' function demonstrates a classic exploit flow: it leaks kernel pointers (task_struct), locates the process's 'cred' structure, and performs an arbitrary write to overwrite Uids to 0 (root). Finally, it verifies elevation via 'getuid()' and executes '/bin/bash' to provide the attacker with a root shell.

Popular threat label: trojan.cve201716995/exploit

Threat categories: trojan

Family labels: cve201716995 exploit genericlinux

Security vendors' analysis

AbusLab-V3	Exploit/Linux.CVE-2017-16995.17880	AliCloud	Exp.Linux/CVE-2017.16995
ALYac	Trojan.Generic.38165578	Antiy-AVL	Trojan(Exploit)/Linux.CVE-2017-16995
Avast	Trojan.Generic.22465C4A	Avast	ELF/CVE-2017-16995-A[Exploit]

Do you want to automate checks?

We can see that the endpoint is running Ubuntu 16.04.4 which immediately increases the urgency of this alert and that the process is currently running.

Host Information

Hostname: KatharinePRD

Domain: LetsDefend

IP Address: 172.16.15.78

Bit Level: 64

OS: Ubuntu 16.04.4

Primary User: katharine

Client/Server: Client

Last Login: Feb, 28, 2021, 08:09 PM

Action

Containment: ☒ Host Contained

Processes 3

Network Action 5

Terminal History 1

Browser History 5

Results: 10

EVENT TIME	PROCESS ID	PROCESS NAME	PARENT PROCESS	COMMAND LINE
▼ No Event Time	No Process ID	Chrome.exe	—	/usr/bin/chrome
▼ 2020-09-22 15:11	No Process ID	xfce4-terminal	—	/usr/bin/xfce4-terminal
▲ 2020-09-22 15:12	No Process ID	creditcard	—	/home/katharine/Document...

The process is running as root which indicates that is succeeded in escalating privileges.

MD5 : 7299c49dd85069e47d6514ab5e10c264

Path : /home/katharine/Documents/creditcard

Size : 17KB

Start Time : 2020-09-22 15:12

Username : root

On VirusTotal the C2 IP 23[.]227.38.71 is associated with cloudflare and so not considered malicious. When scanned the domain was also listed as clean.

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a True Positive alert for privilege escalation on the Linux host KatharinePRD (172[.]16.15.78). The attack originated from a socially engineered phishing email containing a malicious attachment named creditcard. Upon execution, the payload successfully exploited a known Linux kernel vulnerability (CVE-2017-16995) to escalate its privileges to the root user and initiated potential C2.

Incident Details

- **Alert Name:** SOC107 - Privilege Escalation Detected
- **Target Host:** KatharinePRD (172[.]16.15.78) running Ubuntu 16.04.4
- **Flagged File:** creditcard
- **File Hash:** 7299c49dd85069e47d6514ab5e10c264
- **Device Action:** Allowed

Analysis and Evidence

- **Delivery Mechanism:** Email logs indicate the payload was delivered via a phishing email sent from the external address david[.]cashbank[.]com to katharine[.]letsdefend[.]io. The email utilised financial lure tactics, claiming urgent fraudulent activity to coerce the user into opening the attachment.
- **Execution & Escalation:** Endpoint telemetry shows the creditcard payload was executed from the /home/katharine/Documents/creditcard directory. Process logs confirm the malware is currently running under the root username.
- **Network Activity:** Firewall logs show potential C2 activity stemming from the malicious file, with the host connecting to the IP 23[.]227.38.71 over port 443, requesting the URL https://amesiana[.]com/.

Threat Intelligence

- **OSINT (Payload):** VirusTotal analysis flags the file as definitively malicious, with 41/62 security vendors detecting it. Code insights identify the payload as a Linux kernel privilege escalation exploit targeting eBPF (Extended Berkeley Packet Filter).
- **Vulnerability:** The malware leverages CVE-2017-16995, leaking kernel pointers and overwriting UIDs to 0 (root) to provide the attacker with a root shell.
- **OSINT (Infrastructure):** On VirusTotal, the destination IP 23[.]227.38.71 is associated with Cloudflare and is not considered malicious. When scanned, the resolving domain (amesiana[.]com) was also listed as clean.

Actions Taken

1. Traced the initial infection vector to a socially engineered phishing email.
2. Analysed the payload hash via VirusTotal, identifying it as a CVE-2017-16995 exploit.

3. Reviewed endpoint processes, confirming the payload successfully bypassed standard user permissions and is actively running as root.
4. Analysed network logs to identify potential C2 communication with amesiana[.]com.
5. Contained the endpoint.
6. Declared the alert a True Positive for successful privilege escalation and escalated.

Let's Defend Result

SOC107 - Privilege Escalation Detected

True Positive (+5 Point)

Check If Someone Requested the C2 (+5 Point)

Analyze Malware (+5 Point)

Check if the malware is quarantined/cleaned (+5 Point)